

Risk Register



security@falconi.com
220 Gardenpoint Plaza, Suite 205, Newark, NJ
(973) 555-1490

Risk ID	Risk	Risk Description	Likelihood	Impact	Mitigation Actions	Informative References
R-1	Phishing Attack	Phishing attacks may lead an employee to unknowingly disclose log-in credentials to a third party, risking unauthorized access, data breaches, and system disruptions	High	High	-Conduct regular phishing awareness training and simulations -Enforce multi-factor authentication(MFA) on all employee accounts -Monitor authentication logs and alert suspicious log in attempts	NIST Phish Scale User Guide
R-2	Natural Disaster	Severe winter weather (snowstorms, ice, power outages) may disrupt office access, employee availability, and systems operations	Low	Low	-Implement regular off-site backups -Have remote work procedures in place -Migrate critical systems to cloud based environments	Newark NJ Snowfall Totals & Snow Accumulation Averages https://nehrrpsearch.nist.gov/static/files/FEMA/PB91193862.pdf
R-3	Brand Impersonation	Attackers may impersonate Falconi or its partners through fake websites, emails, or social media to deceive athletes or clients into sharing personal data, financial info, or signing fraudulent contracts. These impersonations can severely damage brand trust and client relationships	High	Medium	-Educate athletes on identifying and reporting potential scams -Establish secure, verified communication channel for official business	CISA - Avoid Social Engineering
R-4	Insider Threat	An employee may intentionally or unintentionally leak sensitive client information, modify information, or launch a DoS/DDoS attack	Low	High	-Conduct background checks -Implement strict access controls and least privilege principles -Enforce a strict off-boarding process	CISA Insider Threat Mitigation Guide
R-5	Zero-Day Vulnerability	An unknown vulnerability in any of the critical softwares (e.g. CRM) that can be exploited by an attacker	Low	High	-Regularly update and patch all software being used -Stay up to date on news about day zero vulnerabilities -Deploy tools to detect abnormal behavior	Collection of newly discovered and reported Zero Day Vulnerabilities
R-6	Unsecure Admin Directory	Use of admin directories and interfaces that contain sensitive unencrypted information that can be found and accessed by an attacker	Medium	High	-Require authentication to access admin areas -Regularly perform scans to find exposed endpoints -Encrypt sensitive information	NIST SP 800-53 Rev. 5 (Security and Privacy Controls for Information Systems and Organizations)

R-7	Forgotten Subdomains	Older or discontinued web applications hosted on forgotten subdomains may contain unpatched vulnerabilities or sensitive information. These neglected applications increase the attack surface and can be exploited to compromise systems or access confidential data.	Medium	High	-Maintain an updated list of all accessible subdomains -Remove discontinued applications and services from servers -Monitor access logs and unusual activity on legacy subdomains	OWASP - Test for Subdomain Takeover
R-8	Misconfigured Network Infrastructure	Insecure or misconfigured network components, such as open ports, weak firewall rules, outdated router firmware, or use of unencrypted protocols. May provide attackers with unauthorized access to internal systems and data.	Medium	High	-Regularly scan for open ports -Implement firewalls to restrict network traffic for unauthorized IP addressed. -Close and block unnecessary and unused ports	NIST SP 800-41 Rev.1 (Guidelines on Firewalls and Firewall Policies)